

# Concise Report

Company Name:

Website Link:

Date:

Time:

https://stackpath.bootstrapcdn.com

2024-10-15

15:23:28

## Risk Summary

### Medium Risk Vulnerabilities

| Vulnerability Name | Count | Count % | Description | Mitigation |
|--------------------|-------|---------|-------------|------------|
|--------------------|-------|---------|-------------|------------|

|                             |   |         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                 |
|-----------------------------|---|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Absence of Anti-CSRF Tokens | 4 | (22.2%) | <p>Based on the info: 'Summary No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy. Solution Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes the ability to detect and prevent session fixation attacks, which can be used in conjunction with CSRF attacks to gain unauthorized access to a user's session. In summary, cross-site request forgery (CSRF) is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. CSRF attacks are effective in situations where the victim has an active session on the target site, is authenticated via HTTP auth on the target site, or is on the same local network as the target site. To prevent CSRF attacks, use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. Use anti-CSRF packages such as the OWASP CSRFGuard. Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Use the ESAPI Session Management control to detect and prevent session fixation attacks, which can be used in conjunction with CSRF attacks to gain unauthorized access to a user's session.</p> | <p>Most CSRF defenses can be bypassed using attacker-controlled script. Use anti-CSRF packages such as the OWASP CSRFGuard. When the user performs a dangerous operation, send a separate confirmation request. Use the "double-submitted cookie" method as described by Felten and Zeller.</p> |
|-----------------------------|---|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|                                              |   |          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                                                                                                                                |
|----------------------------------------------|---|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Content Security Policy (CSP) Header Not Set | 3 | (216.7%) | The vulnerability can be described as a missing Content Security Policy (CSP) header and an obsolete Content Security Policy (CSP) header being found in the system. The first vulnerability (10038-1) refers to a missing Content Security Policy (CSP) header, while the second vulnerability (10038-2) refers to an obsolete Content Security Policy (CSP) header. The third vulnerability (10038-3) indicates the presence of a report-only header within the Content Security Policy (CSP). To address this vulnerability, it is crucial to set the Content Security Policy (CSP) headers correctly and ensure that they are up-to-date and relevant to the application's requirements. This can be achieved by reviewing and modifying the existing Content Security Policy (CSP) settings or by implementing a new one if necessary. Additionally, removing any report-only headers from the Content Security Policy (CSP) is essential to mitigate the third vulnerability. | Use vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. Run the code in a "jail" or similar sandbox environment that enforces strict boundaries between the process and the operating system. If possible, create isolated accounts with limited privileges. Assume all input is malicious. |
| Cross-Domain Misconfiguration                | 6 | (33.3%)  | The vulnerability allows an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing. This is possible because the Cross Origin Resource Sharing (CORS) misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. The misconfiguration could be used by an attacker to access data that is otherwise protected by other security measures.                                                                                                                                                                                                                                                                                          | Compartmentalize the system to have "safe" areas where trust boundaries can be unambiguously drawn. Architects and designers should rely on the principle of least privilege to decide the appropriate time to use privileges and the time to drop privileges. Always be careful when interfacing with a compartment outside of the safe area.                                 |
| Vulnerable JS Library                        | 2 | (11.1%)  | The vulnerability in ExampleLibrary version x.y.z can be described as a security issue where the library does not properly handle certain types of input, potentially leading to arbitrary code execution. This can be exploited by malicious actors to compromise the security of systems utilizing this library. The solution to this vulnerability is to upgrade to the latest version of ExampleLibrary, which has implemented proper handling of input and addresses this security issue.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Leverage the HttpOnly flag when setting a sensitive cookie in a response. Attackers might also be able to use XMLHttpRequest to read the headers directly and obtain the cookie. While this mitigation is effective for protecting cookies from a browser's own scripting engine, third-party components or plugins may have their own engines that allow access to cookies.   |

## Low Risk Vulnerabilities

| Vulnerability Name           | Count | Count % | Description                                                                                                                                                                                                                                                                                                                                                | Mitigation                                                                                                                                                                                                                                                                                 |
|------------------------------|-------|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Application Error Disclosure | 4     | (22.2%) | The vulnerability is that an error/warning message on the page may reveal sensitive information such as the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page. | Use SSL for the entire session from login to logout, not just for the initial login page. Use tools and techniques that require manual (human) analysis, such as penetration testing, threat modeling, and interactive tools that allow the tester to record and modify an active session. |
| Cookie No HttpOnly Flag      | 12    | (66.7%) | The vulnerability is that a cookie can be accessed by JavaScript if it is not set with the HttpOnly flag. This can lead to the cookie being transmitted to another site and potentially allowing for session hijacking if the cookie is a session cookie.                                                                                                  | Consider using language-theoretic security (LangSec) techniques that characterize inputs using a formal language. Use an input validation framework such as Struts or the OWASP ESAPI Validation API. Explicitly set the encoding you are using whenever the protocol allows you to.       |

|                                                                          |    |         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |  |
|--------------------------------------------------------------------------|----|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|
| Private IP Disclosure                                                    | 4  | (22.2%) | The description of the vulnerability is that a private IP address or an Amazon EC2 private hostname has been found in the HTTP response body, which can potentially be used for further attacks targeting internal systems. This information should not be included in the response body, as it can expose sensitive information to potential attackers.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |  |
| Server Leaks Version Information via "Server" HTTP Response Header Field | 61 | (38.9%) | The vulnerability can be described as a leak of server information and the webserver application through specific HTTP response header fields in the server. This can potentially lead to unauthorized access to sensitive information and compromise the security of the system. The vulnerability is caused by the code or g/zaproxy/zap/extension/pscanrules/ServerHeaderInfoLeakScanRule.java, which leaks version information and the webserver application via the "Server" HTTP response header field.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |  |
| Strict-Transport-Security Header Not Set                                 | 3  | (16.7%) | Vulnerability Description: The Strict-Transport-Security (STS) header is a security feature implemented in web applications to prevent downgrade attacks. This header informs the browser to only communicate with the server over HTTPS, and not to consider HTTP as a valid connection. Vulnerabilities: 1. Strict-Transport-Security Header Not Set (10035-1): This vulnerability occurs when the STS header is not set in the HTTP response. Attackers can exploit this vulnerability by forcing the browser to use HTTP instead of HTTPS. 2. Strict-Transport-Security Disabled (10035-2): This vulnerability occurs when the STS header is disabled in the web application. Attackers can exploit this vulnerability by disabling the STS header and allowing HTTP connections. 3. Strict-Transport-Security Multiple Header Entries (Non-compliant with Spec) (10035-3): This vulnerability occurs when the web application has multiple STS header entries that are not compliant with the specification. Attackers can exploit this vulnerability by manipulating the STS headers to bypass security measures. 4. Strict-Transport-Security Header on Plain HTTP Response (10035-4): This vulnerability occurs when the STS header is present in the HTTP response but not properly configured. Attackers can exploit this vulnerability by intercepting the HTTP response and modifying the STS header. 5. St |  |
| X-Content-Type-Options Header Missing                                    | 7  | (38.9%) | The vulnerability allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |  |